Aldermoor Health Trust - Supplier Information Security Requirements

Appendix C to the Invitation to Tender. Every item is mandatory unless stated.

Identity and access

- Staff sign in through single sign-on with Microsoft Entra ID (OIDC or SAML 2.0). No local staff passwords.
- Multi-factor authentication for every administrative account, including supplier support staff.
- Role-based access: booking clerk, clinician, service lead, administrator. Least privilege by default.
- Patient sign-in method is not yet decided (national citizen login or Trust-managed accounts with SMS one-time codes). The supplier must price both or state an assumption.

Data protection

- Patient data is special category personal data. The supplier acts as processor and signs the Trust's data processing agreement.
- All data at rest encrypted with AES-256; in transit with TLS 1.2 or higher.
- Data residency: United Kingdom only, including backups and logs.
- Data retention follows the Trust records management policy; portal audit logs 8 years.

Assurance

- ISO 27001 certification of the supplier's hosting and support, or equivalent evidence.
- Independent penetration test before go-live and annually; critical and high findings fixed before go-live at the supplier's cost.
- Supplier staff with access to patient data complete data security training every year.
- Vulnerability patching: critical within 14 days, high within 30 days.

Operations

- Security incidents reported to the Trust within 24 hours of detection.
- Remote support access only through the Trust's privileged access gateway; accounts take about four weeks to approve.
- Logs forwarded to the Trust security operations centre (syslog or Azure Monitor).